

Programa de Auditoría Interna 2026

OpenTrust Demo Services, S.L. · AUD-PLN-2026 · Versión 1.0

DATOS DE DEMOSTRACIÓN - ORGANIZACIÓN FICTICIA

Código	AUD-PLN-2026
Propietario	GRC
Versión	1.0
Fecha de aprobación	15/01/2026
Próxima revisión	15/01/2027
Clasificación	Uso interno - Demo
Controles relacionados	9.2, A.5.35

1. Objetivo y alcance

Evaluar la conformidad, diseño y eficacia operativa del SGSI de la organización ficticia, incluyendo Azure, Microsoft 365, sedes, teletrabajo, desarrollo, proveedores y continuidad.

2. Equipo

Rol	Persona demo	Independencia
Auditor líder	Miguel Ángel Carriazo	No opera los controles auditados
Auditor técnico	Laura Martínez	Independiente de Infraestructura
Observador	Carlos Vega	Formación

3. Calendario

Fecha	Proceso	Controles	Muestreo
22/07/2026	Contexto, gobierno y riesgos	4-6, 8.2-8.3	Riesgos, SoA, objetivos
29/07/2026	Personas e identidades	A.5.15-A.5.18, A.6	10 identidades
05/08/2026	Operaciones y tecnología	A.8.1-A.8.24	3 meses de registros
12/08/2026	Proveedores y continuidad	A.5.19-A.5.30	6 proveedores
02/09/2026	Evaluación y mejora	9-10	Hallazgos y acciones

4. Criterios de muestreo

- Controles periódicos: al menos tres ejecuciones.
- Accesos: diez identidades o universo completo si es menor.
- Cambios: cinco cambios de producción, incluyendo uno urgente.
- Incidentes: todos los de severidad alta y una muestra de media/baja.
- Proveedores: todos los críticos y una muestra de los medios.

5. Plan de entrevistas

Área	Entrevistado demo	Temas
Dirección	Directora General	Objetivos, recursos y revisión
CISO	Responsable de Seguridad	Riesgos, incidentes y métricas
IT	Responsable de Infraestructura	Identidad, red, backups
Desarrollo	CTO	SDLC, cambios y CI/CD
RRHH	Responsable de Personas	Altas, bajas y formación

Compras	Responsable de Proveedores	Evaluación y contratos
---------	----------------------------	------------------------

6. Resultados preliminares demo

Tipo	Cantidad	Ejemplo
No conformidad mayor	1	SLA de vulnerabilidades no aprobado
No conformidad menor	2	Recertificación y retención de logs
Observación	3	Formación, proveedores y cambios
Fortaleza	4	MFA, copias, SIEM y gestión de incidentes